



# ANALYST,reviewer

## Web Application & API Penetration Test Report

May 06, 2026



## Confidentiality and Distribution Restrictions

---

The conclusions and recommendations in this report represent the opinions of Securify. Determinations of appropriate corrective action(s) are the responsibility of the entity receiving the report. This report and any other materials furnished by Securify in connection with this engagement are confidential and may not be duplicated, modified, or otherwise reproduced and distributed without the express prior written consent of Securify or Client Name.

# Table of Contents

---

|                                              |           |
|----------------------------------------------|-----------|
| <b>Table of Contents</b>                     | <b>3</b>  |
| <b>Introduction</b>                          | <b>4</b>  |
| <b>Approach</b>                              | <b>5</b>  |
| Runtime Application Vulnerability Assessment | 5         |
| <b>Scope</b>                                 | <b>6</b>  |
| Application Details                          | 6         |
| User Roles (Web application & API)           | 6         |
| Tools                                        | 6         |
| Assessment Limitation                        | 7         |
| <b>Findings and Recommendation</b>           | <b>8</b>  |
| Risk Classification                          | 8         |
| Measurement of Impact                        | 8         |
| Measurement of Likelihood                    | 9         |
| Overall Risk                                 | 10        |
| Zero-risk Issues                             | 10        |
| <b>Vulnerabilities</b>                       | <b>11</b> |
| Summary                                      | 11        |
| Detailed Vulnerabilities                     | 12        |
| Privilege Escalation                         | 12        |
| Account Takeover via Host Header Injection   | 15        |
| Open Redirection                             | 18        |
| Cross-origin Resource Sharing                | 20        |
| Weak Password Policy in Use                  | 22        |
| <b>Appendix A</b>                            | <b>24</b> |

## Introduction

---

As part of an ongoing security program, ANALYST,reviewrer identified the need to conduct an application security assessment of its Web application & APIs.

This report presents the agreed scope, methodology, risk measurement model, summarized findings, and detailed technical observations for the selected assessment window.

The following lists the objectives of this assessment:

- Determine the overall security posture of the application
- Provide a list of key findings and recommendations for remediation
- Document the assessment scope, risk evaluation, and final outcomes
- Support remediation planning with actionable technical detail

This report includes the following parameters and results of the assessment:

## Approach

---

Securify performed a Runtime Application Vulnerability Assessment of the client environment using a combination of manual testing, guided analysis, and targeted verification of identified attack paths.

Testing focused on authentication, authorization, business logic, session management, input handling, information disclosure, and transport-layer protections.

Where appropriate, the assessment also included abuse-case validation, access-control bypass attempts, forced browsing, parameter tampering, and endpoint enumeration.

### Runtime Application Vulnerability Assessment

The runtime assessment focused on security behavior observable in the live application and API flows, including authentication, authorization, input handling, business logic, sensitive data exposure, and common attack-surface weaknesses.

The engagement emphasized practical exploitability and realistic attacker behavior rather than purely theoretical weaknesses.

- **Information Gathering** - The application was reviewed as an anonymous, authenticated, and privileged user to understand differences in access and behavior.
- **Authentication Testing** - Authentication mechanisms were evaluated to determine the strength of login controls, password policies, and account recovery processes.
- **Authorization Testing** - Tests were conducted to identify weaknesses in access control, including attempts to access other users' data or privileged functionality.
- **Session Management** - Session handling was assessed to ensure secure creation, storage, and invalidation of session tokens.
- **Input Validation Attacks** - User-controlled input fields were tested with malformed and malicious data to identify injection flaws and logic bypasses.
- **Business Logic Testing** - The application workflows were reviewed to identify opportunities to misuse or bypass intended processes.

## Scope

---

The assessment was conducted between Start Date and End Date. The re-assessment was conducted between Start Date and End Date. Testing was performed remotely.

The scope of the assessment was limited to the environments and targets below:

### Application Details

| Name               | URL                   |
|--------------------|-----------------------|
| Application Name 1 | http://test.com       |
| Application Name 2 | http://admin.test.com |

### User Roles (Web application & API)

| Role     | Description                    |
|----------|--------------------------------|
| Customer | Authenticated customer user    |
| Admin    | Privileged administrative user |

### Tools

| Tool Name             | Description                                                                |
|-----------------------|----------------------------------------------------------------------------|
| Burp Professional Pro | An advanced proxy for testing web security.                                |
| OpenSSL               | An open-source package to assess security in transit.                      |
| Nmap                  | A tool used to discover hosts and services on a network.                   |
| SQLMap                | Python-based CLI tool that identifies SQL injection issues.                |
| Acunetix Pro          | An automated scanner to perform authenticated scans on the web app / APIs. |
| cURL Utility          | Command line utility to perform HTTP/s requests.                           |

The following components and tests were out of scope for this review:

- Any applications and infrastructure external to the ANALYST,reviewer's Web Application & API.
- In cases where the ANALYST,reviewer's Web Application & API had inbound and/or outbound interfaces with.
- Another application, the interfaces, and communications were considered in scope. All other external elements were excluded.
- Supporting policies, procedures, and processes.
- Social Engineering.
- Software Development Life Cycle.

## Assessment Limitation

This assessment was performed within the agreed timebox and only against systems explicitly included in scope. Absence of identified vulnerabilities should not be interpreted as a guarantee that no issues remain. Security posture can change over time as the application, infrastructure, integrations, and threat landscape evolve.



## Findings and Recommendation

### Risk Classification

Risk is determined by evaluating the combined effect of impact and likelihood for each issue identified during testing. The matrix below is used as the standard model for determining overall severity.

### Measurement of Impact

Impact is an estimation of the potential damage via a successful exploit of a vulnerability. We'll use the following factors to help qualitatively determine the impact of a vulnerability.

- **Low Impact:** When most/all factors indicate limited consequences (e.g., non-sensitive data, no ability to alter/delete key data, and low victim count).
- **Medium Impact:** When about half of the factors suggest higher damage and half point to limited effects.
- **High Impact:** When most/all factors highlight significant damage (e.g., sensitive data loss, wide data corruption, and a large number of victims).

| Factor                      | Description                                                                                                                                                  | Effect on Impact                                                               |
|-----------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------|
| Classification of Data Loss | If an attacker exploited this vulnerability, what type of data would they access or steal? Non-sensitive, non-customer-specific data would lower the impact. | Less critical data reduces the overall impact.                                 |
| Data Integrity              | Could the attacker modify or delete data they shouldn't? If yes, what kind of data could they corrupt?                                                       | Non-critical or limited modification rights reduce the impact of exploitation. |
| Blast Radius                | How many users or systems would be affected by this vulnerability? For instance, an obscure service affects fewer users, while a public system affects many. | A small number of victims lowers the severity.                                 |

### Measurement of Likelihood

Likelihood is a qualitative estimation of the probability of an attacker exploiting the vulnerability in question. In order to determine the likelihood of exploitation, we can consider the following factors:

- **Low Likelihood:** Most/all factors suggest significant barriers to exploitation (e.g., complex

skillset, limited attackers, high cost, or complex delivery).

- **Medium Likelihood:** About half the factors indicate ease of exploitation, while the other half show barriers.
- **High Likelihood:** Most/all factors point to easy and accessible exploitation (e.g., basic skills, low cost, and simple attack mechanisms).

| Factor                           | Description                                                                                                                                  | Effect on Likelihood                                                           |
|----------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------|
| Required Skill Level of Attacker | How technically skilled does the attacker need to be to exploit the vulnerability? The higher the required skills, the lower the likelihood. | Complex skill requirements lower the chances of exploitation.                  |
| Number of Potential Attackers    | How many attackers could potentially exploit this vulnerability? If access to the system is limited, fewer attackers can exploit it.         | Fewer attackers reduce the probability of exploitation.                        |
| Cost of Exploit                  | How expensive are the tools or resources required for exploitation? High costs reduce accessibility for attackers.                           | Expensive tools lower the likelihood of exploitation.                          |
| Ease of Exploit                  | How simple is it for the attacker to exploit the vulnerability once discovered? Does it rely on external events or tools?                    | Complex or multi-step scenarios reduce the chances of successful exploitation. |

## Overall Risk

The following graph illustrates how Impact x Likelihood scores translate to overall Low, Medium, and High-risk ratings:

- Low Impact + Low Likelihood = Low Risk
- High Impact + High Likelihood = Critical Risk

|        |        |          |
|--------|--------|----------|
| Medium | High   | Critical |
| Low    | Medium | High     |
| Low    | Low    | Medium   |

## Zero-risk Issues

There are cases where a particular issue doesn't have direct security impact or likelihood of exploitation. These could be issues related to documentation or semantics that are suggested based on the security assessors' technical and industry experience. Such issues shall be reported with an Informational risk rating.

# Vulnerabilities

## Summary

Below is a summary of the vulnerabilities discovered during the assessment, ranked in order of risk as determined:

| Vulnerability                                                                   | Risk |
|---------------------------------------------------------------------------------|------|
| Information Disclosure via Unreferenced Endpoint Exposes Sensitive Bidding Data | High |

## Detailed Vulnerabilities

### Information Disclosure via Unreferenced Endpoint Exposes Sensitive Bidding Data

**Risk: High**

#### Description:

An internal endpoint, 'exportbids.php', within the seller portal is accessible to authenticated sellers and exposes sensitive bidding data. This endpoint is not referenced or linked within the user interface, but it can be discovered through common enumeration techniques. Upon accessing this endpoint, authenticated sellers are able to retrieve maximum bid values set by other bidders during live auctions, which should remain confidential to maintain fair bidding practices.

#### Affected URL:

<https://www.alpha.auctionninja.com/portal/exportbids.php?pid=1910204&backto=items&backid=257>

#### Impact and Likelihood:

- Impact:

The impact of this vulnerability is high as it leads to the unauthorized disclosure of confidential maximum bid values. This information is critical for maintaining the integrity and fairness of live auctions. Exposure of such data could allow malicious or opportunistic sellers to gain an unfair advantage, manipulate bidding strategies, or undermine the trust of participants in the auction platform, potentially leading to financial losses or reputational damage.

- **Likelihood:**

The likelihood of exploitation is high because the endpoint, although unreferenced in the UI, can be easily discovered by any authenticated seller through educated guessing or common endpoint enumeration techniques. No specific authorization beyond being an authenticated seller appears to be required to access the sensitive data, making it readily available to a broad range of users.

### **Steps to Reproduce:**

**Step 1:** Log in to the seller portal as an authenticated seller.

**Step 2:** Construct a URL to access the 'exportbids.php' endpoint, for example:  
'https://www.alpha.auctionninja.com/portal/exportbids.php?pid=1910204&backto=items&backid=257'.

**Step 3:** Navigate to the constructed URL in the browser.

**Step 4:** Observe that the response contains sensitive maximum bid values for the specified auction, which should not be accessible to sellers.

### **Recommendations:**

**Access Control:** Implement robust server-side access control checks for the 'exportbids.php' endpoint to ensure that only authorized personnel with a legitimate business need can access this sensitive information. This should include verifying the user's role and specific permissions beyond mere authentication.

**Endpoint Management:** Conduct a comprehensive review of all internal and unreferenced endpoints to identify and secure any other potential information disclosure vulnerabilities. Ensure that endpoints not intended for general user access are properly protected or removed.

**Information Disclosure:** Ensure that sensitive data, such as maximum bid values, is never exposed to unauthorized users. Redesign the data retrieval process to only provide information relevant and appropriate for the requesting user's role and context.

### **References:**

- [https://owasp.org/www-project-top-ten/2021/A01\\_2021-Broken\\_Access\\_Control](https://owasp.org/www-project-top-ten/2021/A01_2021-Broken_Access_Control)
- <https://cwe.mitre.org/data/definitions/200.html>
- <https://cwe.mitre.org/data/definitions/284.html>

## Appendix A

| Penetration Test Scope |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
|------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| V1                     | Authentication Verification Requirements                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
| V1.1                   | Password Security Requirements                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| 1.1.1                  | Verify that user-set passwords are at least 12 characters in length                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| 1.1.2                  | Verify that passwords 64 characters or longer are permitted                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| 1.1.3                  | Verify that passwords can contain spaces and that truncation is not performed. Consecutive multiple spaces MAY optionally be coalesced                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| 1.1.4                  | Verify that Unicode characters are permitted in passwords. A single Unicode code point is considered a character, so 12 emoji or 64 kanji characters should be valid and permitted                                                                                                                                                                                                                                                                                                                                                                                             |
| 1.1.5                  | Verify users can change their password                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| 1.1.7                  | Verify that passwords submitted during account registration, login, and password change are checked against a set of breached passwords either locally (such as the top 1,000 or 10,000 most common passwords that match the system's password policy) or using an external API. If using an API a zero-knowledge proof or other mechanism should be used to ensure that the plain text password is not sent or used in verifying the breach status of the password. If the password is breached, the application must require the user to set a new non non-breached password |
| 1.1.8                  | Verify that a password strength meter is provided to help users set a stronger password                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| 1.1.9                  | Verify that there are no password composition rules limiting the type of characters permitted. There should be no requirement for upper or lower case or numbers or special characters                                                                                                                                                                                                                                                                                                                                                                                         |
| 1.1.10                 | Verify that "paste" functionality, browser password helpers, and external password managers are permitted                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| 1.1.11                 | Verify that the user can choose to either temporarily view the entire masked password, or temporarily view the last typed character of the password on platforms that do not have this as native functionality                                                                                                                                                                                                                                                                                                                                                                 |
| V1.2                   | General Authenticator Requirements                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |

|       |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
|-------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 1.2.1 | Verify that anti-automation controls are effective at mitigating breached credential testing, brute force, and account lockout attacks. Such controls include blocking the most common breached passwords, soft lockouts, rate limiting, CAPTCHA, ever-increasing delays between attempts, IP address restrictions, or risk-based restrictions such as location, first login on a device, recent attempts to unlock the account, or similar. Verify that no more than 100 failed attempts per hour is possible on a single account |
| 1.2.2 | Verify that the use of weak authenticators (such as SMS and email) is limited to secondary verification and transaction approval and not as a replacement for more secure authentication methods. Verify that stronger methods are offered before weak methods, that users are aware of the risks, or that proper measures are in place to limit the risks of account compromise                                                                                                                                                   |
| 1.2.3 | Verify that secure notifications are sent to users after updates to authentication details, such as credential resets, email or address changes, and logging in from unknown or risky locations. The use of push notifications - rather than SMS or email - is preferred, but in the absence of push notifications, SMS or email is acceptable as long as no sensitive information is disclosed in the notification                                                                                                                |
| 1.2.4 | Verify impersonation resistance against phishing, such as the use of multi-factor authentication, cryptographic devices with intent (such as connected keys with a push to authenticate), or at higher ALL levels, client-side certificates                                                                                                                                                                                                                                                                                        |
| 1.2.5 | Verify that where a credential service provider (CSP) and the application verifying authentication are separated, mutually authenticated TLS is in place between the two endpoints                                                                                                                                                                                                                                                                                                                                                 |
| V1.3  | Credential Recovery Requirements                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| 1.3.1 | Verify that a system-generated initial activation or recovery secret is not sent in clear text to the user                                                                                                                                                                                                                                                                                                                                                                                                                         |
| 1.3.2 | Verify password hints or knowledge-based authentication (so-called "secret questions") are not present                                                                                                                                                                                                                                                                                                                                                                                                                             |
| 1.3.3 | Verify password credential recovery does not reveal the current password in any way                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| 1.3.4 | Verify shared or default accounts are not present (e.g. "root", "admin", or "sa").                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| 1.3.5 | Verify that if an authentication factor is changed or replaced, the user is notified of this event                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| 1.3.6 | Verify forgotten passwords, and other recovery paths using a secure recovery mechanism, such as TOTP or another soft token, mobile push, or another offline recovery mechanism                                                                                                                                                                                                                                                                                                                                                     |

|       |                                                                                                                                                                                                                                                                       |
|-------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 1.3.7 | Verify that if OTP or multi-factor authentication factors are lost, that evidence of identity proofing is performed at the same level as during enrolment                                                                                                             |
| V1.4  | Single or Multi-Factor One Time Verifier Requirements                                                                                                                                                                                                                 |
| 1.4.1 | Verify that time-based OTPs have a defined lifetime before expiring                                                                                                                                                                                                   |
| 1.4.2 | Verify that symmetric keys used to verify submitted OTPs are highly protected, such as by using a hardware security module or secure operating system-based key storage                                                                                               |
| 1.4.3 | Verify that time-based OTP can be used only once within the validity period                                                                                                                                                                                           |
| 1.4.4 | Verify that if a time-based multi-factor OTP token is re-used during the validity period, it is logged and rejected with secure notifications being sent to the holder of the device                                                                                  |
| V2    | Session Management Verification Requirements                                                                                                                                                                                                                          |
| V2.1  | Fundamental Session Management Requirements                                                                                                                                                                                                                           |
| 2.1.1 | Verify the application never reveals session tokens in URL parameters or error messages                                                                                                                                                                               |
| 2.1.1 | Verify the application generates a new session token on user authentication                                                                                                                                                                                           |
| 2.1.2 | Verify that session tokens possess at least 64 bits of entropy                                                                                                                                                                                                        |
| 2.1.3 | Verify the application only stores session tokens in the browser using secure methods such as appropriately secured cookies or HTML 5 session storage                                                                                                                 |
| V2.2  | Session Logout and Timeout Requirements                                                                                                                                                                                                                               |
| 2.2.1 | Verify that logout and expiration invalidate the session token, such that the back button or a downstream relying party does not resume an authenticated session, including across relying parties                                                                    |
| 2.2.2 | If authenticators permit users to remain logged in, verify that re-authentication occurs periodically both when actively used or after an idle period. (C6) 30 days 12 hours or 30 minutes of inactivity, 2FA optional 12 hours or 15 minutes of inactivity, with 2FA |
| 2.2.3 | Verify that the application terminates all other active sessions after a successful password change and that this is effective across the application, federated login (if present), and any relying parties                                                          |
| 2.2.4 | Verify that users are able to view and log out of any or all currently active sessions and devices                                                                                                                                                                    |
| V2.3  | Cookie-based Session Management                                                                                                                                                                                                                                       |
| 2.3.1 | Verify that cookie-based session tokens have the 'Secure' attribute set                                                                                                                                                                                               |



|       |                                                                                                                                                                                                                                                                                          |
|-------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 2.3.2 | Verify that cookie-based session tokens have the 'HttpOnly' attribute set                                                                                                                                                                                                                |
| 2.3.3 | Verify that cookie-based session tokens utilize the 'SameSite' attribute to limit exposure to cross-site request forgery attacks                                                                                                                                                         |
| 2.3.4 | Verify that cookie-based session tokens use "__Host-" prefix (see references) to provide session cookie confidentiality                                                                                                                                                                  |
| 2.3.5 | Verify that if the application is published under a domain name with other applications that set or use session cookies that might override or disclose the session cookies, set the path attribute in cookie-based session tokens using the most precise path possible                  |
| V2.4  | Token-based Session Management                                                                                                                                                                                                                                                           |
| 2.4.2 | Verify the application uses session tokens rather than static API secrets and keys, except with legacy implementations                                                                                                                                                                   |
| 2.4.3 | Verify that stateless session tokens use digital signatures, encryption, and other countermeasures to protect against tampering, enveloping, replay, null cipher, and key substitution attacks                                                                                           |
| V3    | Access Control Verification Requirements                                                                                                                                                                                                                                                 |
| V3.1  | Operation Level Access Control                                                                                                                                                                                                                                                           |
| 3.1.2 | Verify that the application or framework enforces a strong anti-CSRF mechanism to protect authenticated functionality, and effective anti-automation or anti-CSRF protects unauthenticated functionality                                                                                 |
| V4    | Validation, Sanitization, and Encoding Verification Requirements Control Objective                                                                                                                                                                                                       |
| V4.1  | Input Validation Requirements                                                                                                                                                                                                                                                            |
| 4.1.1 | Verify that the application has defenses against HTTP parameter pollution attacks, particularly if the application framework makes no distinction about the source of request parameters (GET, POST, cookies, headers, or environment variables)                                         |
| 4.1.2 | Verify that frameworks protect against mass parameter assignment attacks, or that the application has countermeasures to protect against unsafe parameter assignment, such as marking fields private or similar                                                                          |
| 4.1.3 | Verify that all input (HTML form fields, REST requests, URL parameters, HTTP headers, cookies, batch files, RSS feeds, etc) is validated using positive validation (whitelisting)                                                                                                        |
| 4.1.4 | Verify that structured data is strongly typed and validated against a defined schema including allowed characters, length and pattern (e.g. credit card numbers or telephone, or validating that two related fields are reasonable, such as checking that suburb and zip/postcode match) |

|        |                                                                                                                                                                                                                                                                                                                                                 |
|--------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 4.1.5  | Verify that URL redirects and forwards only allow whitelisted destinations, or show a warning when redirecting to potentially untrusted content                                                                                                                                                                                                 |
| 4.1.6  | Verify that all untrusted HTML input from WYSIWYG editors or similar is properly sanitized with an HTML sanitizer library or framework feature                                                                                                                                                                                                  |
| 4.1.7  | Verify that unstructured data is sanitized to enforce safety measures such as allowed characters and length                                                                                                                                                                                                                                     |
| 4.1.8  | Verify that the application sanitizes user input before passing to mail systems to protect against SMTP or IMAP injection                                                                                                                                                                                                                       |
| 4.1.9  | Verify that the application avoids the use of eval() or other dynamic code execution features. Where there is no alternative, any user input being included must be sanitized or sandboxed before being executed                                                                                                                                |
| 4.1.10 | Verify that the application protects against template injection attacks by ensuring that any user input being included is sanitized or sandboxed                                                                                                                                                                                                |
| 4.1.11 | Verify that the application protects against SSRF attacks, by validating or sanitizing untrusted data or HTTP file metadata, such as filenames and URL input fields, using whitelisting of protocols, domains, paths, and ports                                                                                                                 |
| 4.1.12 | Verify that the application sanitizes, disables, or sandboxes user-supplied SVG scriptable content, especially as they relate to XSS resulting from inline scripts, and foreign Objects                                                                                                                                                         |
| 4.1.13 | Verify that the application sanitizes, disables, or sandboxes user-supplied scriptable or expression template language content, such as Markdown, CSS or XSL stylesheets, BBCode, or similar                                                                                                                                                    |
| V4.2   | Output encoding and Injection Prevention Requirements                                                                                                                                                                                                                                                                                           |
| 4.2.1  | Verify that output encoding is relevant for the interpreter and context required. For example, use encoders specifically for HTML values, HTML attributes, JavaScript, URL Parameters, HTTP headers, SMTP, and others as the context requires, especially from untrusted inputs (e.g. names with Unicode or apostrophes, such as ねこ or O'Hara). |
| 4.2.2  | Verify that output encoding preserves the user's chosen character set and locale, such that any Unicode character point is valid and safely handled                                                                                                                                                                                             |
| 4.2.3  | Verify that context-aware, preferably automated - or at worst, manual - output escaping protects against reflected, stored, and DOM-based XSS                                                                                                                                                                                                   |
| 4.2.4  | Verify that data selection or database queries (e.g. SQL, HQL, ORM, NoSQL) use parameterized queries, ORMs, entity frameworks, or are otherwise protected from database injection attacks                                                                                                                                                       |

|        |                                                                                                                                                                                                                          |
|--------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 4.2.5  | Verify that where parameterized or safer mechanisms are not present, context-specific output encoding is used to protect against injection attacks, such as the use of SQL escaping to protect against SQL injection     |
| 4.2.6  | Verify that the application protects against JavaScript or JSON injection attacks, including for eval attacks, remote JavaScript includes, CSP bypasses, DOM XSS, and JavaScript expression evaluation.                  |
| 4.2.7  | Verify that the application protects against LDAP Injection vulnerabilities, or that specific security controls to prevent LDAP Injection have been implemented                                                          |
| 4.2.8  | Verify that the application protects against OS command injection and that operating system calls use parameterized OS queries or use contextual command line output encoding                                            |
| 4.2.9  | Verify that the application protects against Local File Inclusion (LFI) or Remote File Inclusion (RFI) attacks.                                                                                                          |
| 4.2.10 | Verify that the application protects against XPath injection or XML injection attacks                                                                                                                                    |
| V4.3   | Deserialization Prevention Requirements                                                                                                                                                                                  |
| 4.3.1  | Verify that serialized objects use integrity checks or are encrypted to prevent hostile object creation or data tampering                                                                                                |
| 4.3.2  | Verify that the application correctly restricts XML parsers to only use the most restrictive configuration possible and to ensure that unsafe features such as resolving external entities are disabled to prevent testE |
| 4.3.3  | Verify that deserialization of untrusted data is avoided or is protected in both custom code and third-party libraries (such as JSON, XML and YAML parsers)                                                              |
| 4.3.4  | Verify that when parsing JSON in browsers or JavaScript-based backends, JSON.parse is used to parse the JSON document. Do not use eval() to parse JSON                                                                   |
| V5     | Error Handling and Logging Verification Requirements                                                                                                                                                                     |
| V5.1   | Error Handling                                                                                                                                                                                                           |
| 5.1.1  | Verify that a generic message is shown when an unexpected or security sensitive error occurs, potentially with a unique ID which support personnel can use to investigate                                                |
| V6     | Data Protection Verification Requirements                                                                                                                                                                                |
| V6.1   | Sensitive Private Data                                                                                                                                                                                                   |
| 6.1.1  | Verify that sensitive data is sent to the server in the HTTP message body or headers, and that query string parameters from any HTTP verb do not contain sensitive data                                                  |
| V7     | Communications Verification Requirements                                                                                                                                                                                 |

|        |                                                                                                                                                                                                                       |
|--------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| V7.1   | Communications Security Requirements                                                                                                                                                                                  |
| 7.1.1  | Verify that secured TLS is used for all client connectivity, and does not fall back to insecure or unencrypted protocols.                                                                                             |
| 7.1.2  | Verify using online or up-to-date TLS testing tools that only strong algorithms, ciphers, and protocols are enabled, with the strongest algorithms and ciphers set as preferred                                       |
| 7.1.3  | Verify that old versions of SSL and TLS protocols, algorithms, ciphers, and configurations are disabled, such as SSLv2, SSLv3, or TLS 1.0 and TLS 1.1. The latest version of TLS should be the preferred cipher suite |
| V8     | Business Logic Verification Requirements                                                                                                                                                                              |
| 8.1.1  | Verify the application will only process business logic flows for the same user in sequential step order and without skipping steps                                                                                   |
| 8.1.2  | Verify the application will only process business logic flows with all steps being processed in realistic human time, i.e. transactions are not submitted too quickly                                                 |
| 8.1.3  | Verify the application has appropriate limits for specific business actions or transactions which are correctly enforced on a per-user basis                                                                          |
| 8.1.4  | Verify the application has sufficient anti-automation controls to detect and protect against data exfiltration, excessive business logic requests, excessive file uploads, or denial of service attacks               |
| 8.1.5  | Verify the application has business logic limits or validation to protect against likely business risks or threats, identified using threat modeling or similar methodologies                                         |
| 8.1.6  | Tested for IDOR's vulnerabilities which would allow other users to retrieve any kind of sensitive information like api key, tokens etc.                                                                               |
| 8.1.7  | Verified Privilege Escalation vulnerabilities which could allow low privilege users to perform arbitrary operations leading potential account takeovers.                                                              |
| 8.1.8  | Verified Privilege Escalation vulnerabilities which could allow users to perform CRUD Operations on behalf of victim users.                                                                                           |
| 8.1.9  | Checked for Information Disclosure vulnerabilities via IDORs which could result in users PII Disclosure (PII).                                                                                                        |
| 8.1.10 | Checked for Broken Access Control issues via browsed forcing.                                                                                                                                                         |
| 8.1.11 | Checked for Mass Assignment vulnerability which could allow attackers to gain extra privileges.                                                                                                                       |
| V9     | File and Resources Verification Requirements                                                                                                                                                                          |

|        |                                                                                                                                                                                                                                                           |
|--------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| V9.1   | File Upload Requirements                                                                                                                                                                                                                                  |
| 9.1.1  | Verify that the application will not accept large files that could fill up storage or cause a denial of service attack                                                                                                                                    |
| V9.2   | File Integrity Requirements                                                                                                                                                                                                                               |
| 9.2.1  | Verify that files obtained from untrusted sources are validated to be of expected type based on the file's content                                                                                                                                        |
| V10    | API and Web Service Verification Requirements                                                                                                                                                                                                             |
| V10.1  | Generic Web Service Security Verification Requirements                                                                                                                                                                                                    |
| 10.1.1 | Verify that all application components use the same encodings and parsers to avoid parsing attacks that exploit different URI or file parsing behavior that could be used in SSRF and RFI attacks                                                         |
| 10.1.2 | Verify that access to administration and management functions is limited to authorized administrators                                                                                                                                                     |
| 10.1.3 | Verify API URLs do not expose sensitive information, such as the API key, session tokens, etc                                                                                                                                                             |
| 10.1.4 | Verify that authorization decisions are made at both the URI, enforced by programmatic or declarative security at the controller or router, and at the resource level, enforced by model-based permissions                                                |
| 10.1.5 | Verify that requests containing unexpected or missing content types are rejected with appropriate headers (HTTP response status 406 Unacceptable or 415 Unsupported Media Type)                                                                           |
| V10.2  | RESTful Web Service Verification Requirements                                                                                                                                                                                                             |
| V11    | Configuration Verification Requirements                                                                                                                                                                                                                   |
| V11.1  | Dependency                                                                                                                                                                                                                                                |
| 11.1.1 | Verify that all components are up to date                                                                                                                                                                                                                 |
| 11.1.2 | Verify that all unneeded features, documentation, samples, configurations are removed, such as sample applications, platform documentation, and default or example users                                                                                  |
| 11.1.3 | Verify that if application assets, such as JavaScript libraries, CSS stylesheets or web fonts, are hosted externally on a content delivery network (CDN) or external provider, Subresource Integrity (SRI) is used to validate the integrity of the asset |
| V11.2  | Unintended Security Disclosure Requirements                                                                                                                                                                                                               |

|        |                                                                                                                                                                                             |
|--------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 11.2.1 | Verify that web or application server and framework error messages are configured to deliver user-actionable, customized responses to eliminate any unintended security disclosures         |
| 11.2.2 | Verify that web or application server and application framework debug modes are disabled in production to eliminate debug features, developer consoles, and unintended security disclosures |
| 11.2.3 | Verify that the HTTP headers or any part of the HTTP response do not expose detailed version information of system components                                                               |
| V11.3  | HTTP Security Headers Requirements                                                                                                                                                          |
| 11.3.1 | Verify that every HTTP response contains a content type header specifying a safe character set (e.g., UTF-8, ISO 8859-1).                                                                   |
| 11.3.2 | Verify that all API responses contain Content-Disposition: attachment; filename="api.json" (or other appropriate filename for the content type).                                            |
| 11.3.3 | Verify that a content security policy (CSPv2) is in place that helps mitigate impact of XSS attacks like HTML, DOM, JSON, and JavaScript injection vulnerabilities                          |
| 11.3.4 | Verify that all responses contain X-Content-Type-Options: nosniff                                                                                                                           |
| 11.3.5 | Verify that HTTP Strict Transport Security headers are included on all responses and for all subdomains, such as Strict-Transport-Security: max-age=15724800; include subdomains            |
| 11.3.6 | Verify that a suitable "Referrer-Policy" header is included, such as "no-referrer" or "same-origin"                                                                                         |
| 11.3.7 | Verify that a suitable X-Frame-Options or Content-Security-Policy: frame ancestors header is in use for sites where content should not be embedded in a third-party site                    |
| V11.4  | Validate HTTP Request Header Requirements                                                                                                                                                   |
| 11.4.1 | Verify that the application server only accepts the HTTP methods in use by the application or API, including pre-flight OPTIONS                                                             |
| 11.4.2 | Verify that the supplied Origin header is not used for authentication or access control decisions, as the Origin header can easily be changed by an attacker                                |
| 11.4.3 | Verify that the cross-domain resource sharing (CORS) Access-Control-Allow-Origin header uses a strict white list of trusted domains to match against and does not support the "null" origin |
| 11.4.4 | Verify that HTTP headers added by a trusted proxy or SSO devices, such as a bearer token, are authenticated by the application                                                              |